

Sherpa Audit Summary

Prepared by Cyfrin

Version 2.0

Lead Auditors

Immeas

MrPotatoMagic

November 23, 2025

Contents

1 About Cyfrin **2**

2 About This Document **2**

3 Disclaimer **2**

4 Copyright and License **2**

5 Audit Overview **3**

6 Audit Scope **3**

7 Public Repository Verification **3**

8 Risk Classification **4**

9 Protocol Summary **4**
9.1 Key Components 4
9.2 Core Flows 4

10 Attestation **5**

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for Sherpa on Sherpa. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number and final status of findings by severity. It closes with Cyfrin's attestation of the review's scope and final remediation status.

It is deliberately abbreviated: the technical detail of individual findings is not reproduced here. The complete audit report, version 2.0 dated November 23, 2025, was delivered to Sherpa, who retain it as the full record of the engagement. This summary was issued on October 29, 2026.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from Sherpa or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 7 days, the Cyfrin team conducted an audit on the Sherpa code provided by Sherpa. The findings consist of 3 Medium & 3 Low severity issues with the remainder being informational and gas optimizations.

Summary

Project Name	Sherpa
Repository	sherpa-vault-smartcontracts
Commit	50eb8ad6ee04...
Fix Commit	d9eccb9a9c99...
Audit Timeline	Nov 13th - Nov 21st, 2025
Methods	Manual Review

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	3	3	0
Low Risk	3	3	0
Informational	6	6	0
Gas Optimizations	1	1	0
Total	13	13	0

6 Audit Scope

The following contracts were in scope:

```
contracts/lib/ShareMath.sol
contracts/lib/Vault.sol
contracts/SherpaUSD.sol
contracts/SherpaVault.sol
```

An additional commit, d9eccb9, made during the mitigations, was also reviewed.

7 Public Repository Verification

After the audit the contracts were moved to a public repository, sherpa-vault-smartcontracts-v1.0. The contracts at commit 33dffed770adc76d7b765a695e82cadd787bec32 were verified to be the same as the last audit fix commit, d9eccb9a9c9943c85a1eba763b8322cd4a8287d0, reviewed in the private repository.

8 Risk Classification

	Impact: High	**Impact: Medium**	**Impact: Low**
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

9 Protocol Summary

Sherpa is a cross-chain yield system composed of a per-chain SherpaVault (ERC20 shares) and a chain-local SherpaUSD (a 6-decimal wrapper for USDC). Users deposit via the vault; funds are held as SherpaUSD in the vault. Deposits land as pending for the current round; on round rollover, pending deposits convert to vault shares at the newly posted `pricePerShare`. The global price is computed each round on the primary chain and then replicated to the secondary chains. Withdrawals can be two-step via the wrapper, or direct if "independence" is enabled. Cross-chain rebalancing is performed when there are large supply differences between chains, by minting/burning SherpaUSD to/from vaults and then adjusting vault accounting.

9.1 Key Components

- **SherpaVault:**
  - **Shares (ERC20):** Represent a claim on SherpaUSD (wrapped USDC) held by the vault.
  - **Rounds & Pricing:** `roundPricePerShare[round]` is set at each roll (round N finalizes the price for N-1). Pending deposits convert to shares at the roll.
  - **Accounting:** `totalStaked` (SherpaUSD held by the vault), `accountingSupply` (logical supply of shares) and `vaultState.totalPending` (current-round deposits not yet converted).
  - **Receipts:** Track a user's pending amount and unredeemed shares until redeemed.
- **SherpaUSD (USDC wrapper):**
  - **Epoch Withdrawals:** Users burn SherpaUSD to create withdrawal receipts, which can be completed once the epoch has advanced.

9.2 Core Flows

- **Deposit & Stake:** `SherpaVault::depositAndStake` pulls USDC from the user via `SherpaUSD::depositToVault`, increments the vault's `totalPending` and records a stake receipt for the creditor.
- **Round Roll (primary chain):** computes the new global price, sets `roundPricePerShare[currentRound]`, mints shares to the vault for local pending deposits, applies the round's yield, clears pending and advances the round.
- **Round Apply (secondary chains):** applies the global price for the new round, mints shares for local pending deposits at that price, moves pending into `totalStaked`, clears pending and advances the round.
- **Claim Shares:** `claimShares(numShares)` or `maxClaimShares()` converts deposit receipts into shares using the price of the round after deposit and moves unredeemed shares from the user's receipt into the user's wallet.
- **Unstake & Withdraw:**
  - **Two-step (default):** `unstakeAndWithdraw(shares, minOut)` burns shares and transfers SherpaUSD to the wrapper, which creates a withdrawal receipt for the user; the user completes the withdrawal in the next epoch.

- **Direct (independence on):** `unstake(shares, minOut)` transfers SherpaUSD straight to the user.
- **Instant Unstake (pending only):** `instantUnstake` / `instantUnstakeAndWithdraw` returns pending deposits 1:1 before round conversion.

10 Attestation

Cyfrin attests that it performed a security review of the Sherpa code provided by Sherpa.

The repositories, commits, review period and findings with their final status are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2025-11-23-cyfrin-sherpa-v2.0.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to Sherpa has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=225d5b739a6c9cecf7c180dade1c119bff9b679fd99c6737aa906a962c0688f2
F=2025-11-23-cyfrin-sherpa-v2.0-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.